International Cybersecurity and Digital Forensics Academy (ICDFA)

GRC105: Incident Management and Business Continuity

INCIDENT RESPONSE PLAN

AND TABLETOP EXERCISE

Student name	Agyeman Emmanuel Atta Senior
Course	GRC105: Incident Management and Business Continuity
Assignment	Incident Response Plan and Tabletop Exercise (20%)
Scenario organisation	Northbridge Skills Institute
Submission date	20 October 2026

Task 1: Incident Classification and Initial Assessment (15 Marks)

1.1 Evidence-Linked Incident Timeline

The timeline maps evidence E01–E08, recorded from Day -1 16:40 WAT to Day 0 08:45 WAT. Confirmed facts are kept separate from working hypotheses and open questions.

ID	Time (WAT)	Confirmed observation	Working hypothesis	Unresolved questions
E01	Day -1 16:40	Finance officer opened an unexpected payroll attachment on FIN-PC07.	Malicious attachment ran a dropper or malware.	Did a macro or code run? Were local admin credentials taken?
E02	Day 0 01:15	M365 audit shows the finance officer signed in from an unfamiliar IP and new device.	Account takeover through stolen credentials or a session token.	Was MFA on, or bypassed? Was the user involved?
E03	Day 0 01:35	Windows logs show svc_backup remote admin logons to FS01 and BAK01.	Attacker abused svc_backup for privilege escalation and lateral movement.	How were the svc_backup credentials obtained? Were backups altered?
E04	Day 0 01:50	Proxy shows FIN-PC07 uploaded 1.2 GB over HTTPS to an unfamiliar cloud service.	Attacker staged and exfiltrated sensitive files.	What was in the upload (PII, finance data, databases)?
E05	Day 0 02:00	Backup console reports successful jobs for FS01 and LMS01.	Backups may have captured files already staged or encrypted.	Are the snapshots clean, corrupted or infected?
E06	Day 0 08:30	EDR and helpdesk report mass file changes on FIN-PC07; FS01 folders hold .locked files and a ransom note.	Ransomware is active; files on FIN-PC07 and FS01 are encrypted.	Which strain is it? Were shadow copies deleted?
E07	Day 0 08:40	Helpdesk: the portal login loads, but learners cannot open materials or submit exams.	LMS01 depends on FS01, which is now locked.	Is LMS01 itself encrypted, or only blocked by the FS01 share?
E08	Day 0 08:45	Ops report the incident contact list on FS01 is inaccessible. Staff phones work.	Contact files are encrypted; corporate email cannot be trusted.	Is M365 email fully compromised, or safe to use?

Alternative explanations for ambiguous events

Event	Alternative explanation
E02: M365 sign-in	The finance officer may have signed in from a personal device or a roaming network/VPN while travelling, so it may not be an account takeover.
E04: HTTPS upload	The 1.2 GB upload could be a legitimate cloud sync or backup job (for example OneDrive or an M365 migration) or a large software update.

1.2 Incident Classification and Initial Severity

Classification: Double-extortion ransomware attack (file encryption plus evidence of data theft). **Severity:** Critical.

Northbridge severity matrix

Level	Criteria
Critical	Widespread disruption of the core mission (e.g. exam failure), active encryption of core servers, compromised domain admin or privileged accounts, or verified exfiltration of sensitive PII or financial records.
High	Significant disruption to business units, ransomware on workstations only, or unconfirmed exfiltration without core infrastructure shutdown.
Medium	Minor operational impact, non-critical endpoint infection, malware contained by EDR, no exfiltration.
Low	Minimal impact, blocked phishing attempt, single policy violation, no downtime.

Why Critical

Factor	Evidence
Operational impact	LMS01 is unusable 135 minutes before a mandatory online exam for 100 learners.
Asset exposure	Active encryption on file server FS01 and workstation FIN-PC07.
Data risk	1.2 GB possibly exfiltrated, which may hold learner PII and financial records.
Infrastructure risk	svc_backup logged on to BAK01 without approval, so backup integrity is in doubt.
Operational blindness	The incident contact list on FS01 cannot be opened.

1.3 Asset Assessment (CIA Triad) and Response Priorities

Asset	Status	Confidentiality	Integrity	Availability
FIN-PC07	Confirmed compromised	High risk (1.2 GB upload)	Compromised (.locked files)	Unavailable
FS01	Confirmed compromised	High risk (shared files exposed)	Compromised (.locked files)	Unavailable (shares down)
LMS01	Confirmed disrupted	Medium risk (FS01 dependency)	Unknown (database integrity unverified)	Unavailable for exams
BAK01	Potentially compromised	Medium risk (svc_backup logon)	High risk (unapproved logon)	Possibly tampered
M365 / Email	Potentially compromised	High risk (unfamiliar IP login)	High risk (token hijack)	Operational but untrusted

Response priorities (exam deadline and backup risk)

Priority	Window (WAT)	Action
1	08:45–09:15	Contain: isolate FIN-PC07, FS01 and BAK01 at the switch/firewall, and revoke M365 session tokens for the finance officer and svc_backup.
2	By 09:15	Decide to **postpone the 11:00 exam**. Restoring LMS01 in 135 minutes, with encrypted file dependencies and unverified backups, risks reinfection or corrupted assessment data.
3	09:15–10:30	Preserve volatile memory and logs on FIN-PC07 and FS01 before any power-down, and physically check the offline Friday 17:00 backup.

1.4 Priority Investigation Questions

Question	How to check	Effect on severity and scope
Q1. What data was in the 1.2 GB upload from FIN-PC07 at 01:50 WAT?	Check proxy/firewall logs for the destination. Analyse a memory dump of FIN-PC07 for staging folders or compression tools (7-Zip, WinRAR).	If it holds learner PII or finance databases, NDPA 2023 breach notification becomes mandatory and privacy risk rises.
Q2. Were backups on BAK01 changed, deleted or encrypted during the 01:35 svc_backup session?	Review BAK01 event logs (Event IDs 4624/4672) and compare backup catalogue checksums with the pre-incident baseline.	If compromised, recovery depends on Friday's disconnected backup, which lengthens the RTO.
Q3. Did the attacker set up persistence or extra accounts in M365?	Run a Unified Audit Log query for all IPs used by the finance officer account over 14 days.	If other accounts or global admin roles were touched, the whole cloud tenant needs remediation.

Task 2: Incident Response Plan and Team Responsibilities (20 Marks)

2.1 Policy and Plan Outline

The policy sets out how Northbridge Skills Institute detects, contains, eradicates and recovers from incidents, in line with NIST SP 800-61 Rev 3 and CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover).

Element	Policy position
Mission	Limit disruption, protect learner PII, meet legal and regulatory duties, and protect the institution's reputation.
Scope	All systems, networks, the M365 tenant, endpoints, data stores, staff and the 1,800 learners.
Incident declaration	The IR Lead alone declares an incident, based on triggers such as active ransomware or confirmed exfiltration.
Authority to isolate	The IR Lead and CSIRT may isolate any endpoint, server, network segment or cloud account immediately, without executive sign-off, when encryption or exfiltration is active.
Documentation	All actions, timeline entries, evidence hashes and decision reasons are logged in one secure incident log.
Review cycle	Annually, and within 7 days of incident closure.
Business continuity link	If RTOs (e.g. 24 hours for core file services) are missed or systems cannot be recovered, the IR Lead escalates to the Executive Team to declare a BCP/DR event.

2.2 CSIRT Structure and Role Definitions

With only 3 IT staff and 1 security analyst, Northbridge uses a six-role CSIRT backed by external support.

Role	Responsibilities	Assigned to
Incident Response Lead (IR Lead)	Overall command, severity declaration, decisions, BCP integration and executive reporting.	Security Analyst
Security Analyst / Investigator	Technical analysis, log parsing, malware triage, EDR sweeps and threat hunting.	Senior Network Administrator
Digital Forensics Specialist	Memory capture, disk imaging, evidence custody and timeline reconstruction.	IT Systems Specialist

Role	Responsibilities	Assigned to
IT Operations Lead / Business Owner	Isolation, staging environment, backup restoration and service validation.	IT Helpdesk Lead
Legal and Privacy Adviser	NDPA 2023 and regulatory reporting duties, breach notification and contract liabilities.	External Legal Counsel
Communications Lead	Staff messaging, learner notices, executive briefings and media queries.	Operations / Registrar Lead

External support (pre-approved retainers)

Provider	Support
External DFIR firm (4-hour SLA)	Complex forensics, ransomware negotiation and decryption triage.
Managed Security Service Provider (MSSP)	24/7 SOC monitoring.
Specialist privacy counsel	NDPA 2023 compliance.

2.3 RACI Matrix

R = Responsible (does the work); A = Accountable (owns and approves); C = Consulted; I = Informed. Each activity has one A.

Activity	IR Lead	Sec Analyst	Forensics	IT Ops	Legal/Privacy	Comms
1. Incident detection and triage	**A**	R	C	C	I	I
2. Detailed technical analysis	**A**	R	R	C	I	I
3. System containment	**A**	R	C	R	I	I
4. Evidence handling and custody	**A**	C	R	C	C	I
5. Stakeholder communication	**A**	I	I	I	C	R
6. Assessment of reporting obligations	C	I	C	I	**A/R**	I
7. Restoration and service return approval	**A**	C	C	R	C	I
8. Incident closure and lessons learned	**A/R**	C	C	C	C	C

2.4 Readiness Checklist and Preparation Improvements

Improvement	Owner	Resources needed	Verification
Immutable and offline backups	IT Ops Lead	Immutable (WORM) storage such as S3 Object Lock, plus monthly air-gapped media.	Quarterly automated sandbox restore and hash check.
Out-of-band incident contact list	Operations Lead	Encrypted messaging group (Signal/WhatsApp) and a printed call tree.	Monthly call-tree test.

Improvement	Owner	Resources needed	Verification
Full EDR and MFA enforcement	Security Analyst	EDR licences for FS01, LMS01 and BAK01; FIDO2/MFA enforcement for M365.	EDR console audit and automated Conditional Access check.
Out-of-band bridge and forensics kit	IR Lead	Forensic laptop, write-blockers, FTK/Autopsy and an isolated LTE hotspot.	Semi-annual toolkit check and tabletop.

Task 3: Response Playbook and Evidence Preservation (25 Marks)

3.1 Incident Response Playbook (First 60 Minutes and First 24 Hours)

Time / stage	Action	Owner	Approval	Evidence to keep	Completion check
08:45–08:55 Containment	Isolate FIN-PC07, FS01 and BAK01 at the switch/VLAN. Do not power off FIN-PC07.	IT Ops	IR Lead	Switch port disable logs, ARP table dump	Network link verified down
08:55–09:05 Containment	Revoke M365 session tokens and reset passwords for the finance officer and svc_backup.	Sec Analyst	IR Lead	M365 audit log export, session termination log	No active sessions in M365
09:05–09:15 Containment	Block the destination cloud IP/domain at the firewall/proxy. Preserve proxy logs.	Sec Analyst	IR Lead	Firewall rule configuration, proxy log export	Egress traffic blocked
09:15–09:35 Investigation	Capture a RAM image of FIN-PC07 with WinPmem/FTK CLI before disk imaging.	Forensics	IR Lead	RAM dump, SHA-256 hash log, capture log	RAM image and hash created
09:35–10:15 Investigation	Physically inspect BAK01 and the disconnected Friday 17:00 backup. Confirm the air gap.	IT Ops / Forensics	IR Lead	Physical vault log, backup drive serial check	Friday backup confirmed offline
10:15–12:00 Investigation	Run an EDR sweep of all 90 workstations for .locked files and staging tools.	Sec Analyst	IR Lead	EDR sweep report, file hash match logs	90 workstations verified clean
12:00–15:00 Eradication	Scrub the M365 tenant, remove malicious rules and OAuth apps, and deploy EDR to all servers.	Sec Analyst	IR Lead	M365 configuration audit report, EDR agent logs	Servers 100% EDR covered
15:00–18:00 Recovery staging	Restore the Friday 17:00 backup to an isolated sandbox VLAN and run an AV/EDR scan.	IT Ops	IR Lead	Sandbox restore job log, vulnerability scan report	No malware in sandbox
18:00–21:00 Validation	Verify database integrity of LMS01 and FS01 records in the sandbox. Run a test query.	IT Ops / Business Owner	Business Owner / IR Lead	Integrity check log, test query results, sign-off form	Data integrity confirmed
21:00–24:00 Recovery	Reconnect LMS01 and FS01 to production under enhanced SIEM monitoring.	IT Ops	IR Lead and Executive	Firewall re-enable log, SIEM alert log	Services live, logs clean

3.2 Justification of Difficult Response Decisions

Decision	Reasoning
1. Containment vs memory preservation	RAM capture needs the machine powered on. Isolating at the switch/VLAN stops ransomware spreading over SMB while the host stays on, so volatile memory can still be captured with WinPmem/FTK.
2. Exam postponement vs unverified restoration	Management may push to reopen LMS01 for the 11:00 exam. Restoring while FS01 dependencies and BAK01 backups are unverified risks reinfection, lost learner work and compromised grading. Postponing protects exam integrity and limits legal exposure under NDPA 2023.

3.3 Evidence Register

ID	Source and item	Collection method and role	Date/time (WAT) and hash	Storage and custody
EVD-01	FIN-PC07 volatile RAM dump	WinPmem capture via USB write-blocker by Forensics Lead.	Day 0 09:30. SHA-256 recorded after capture.	Encrypted forensic drive in a physical safe. Access: Forensics Lead only.
EVD-02	FIN-PC07 physical disk image	FTK Imager bit-stream image (.E01) by Forensics Lead.	Day 0 10:15. SHA-256 recorded after capture.	Encrypted, air-gapped evidence NAS. Custody transfer log kept.
EVD-03	FS01 shared directory and ransom note	Live logical collection of .locked files and ransom note text.	Day 0 09:10. SHA-256 recorded after capture.	Write-protected forensic container. Access: CSIRT analyst team.
EVD-04	M365 and proxy HTTPS upload logs	CSV/JSON export from M365 Unified Audit and proxy.	Day 0 09:00. SHA-256 recorded after export.	Read-only cloud evidence vault. Access: IR Lead and Legal Counsel.

3.4 Eradication, Persistence Removal and Recovery Acceptance Criteria

Area	Requirement
Eradication and credentials	Revoke all Kerberos and session tokens; disable svc_backup and the finance officer's M365 account; force a password reset for all 90 staff; re-image FIN-PC07 from a clean ISO; remove unauthorised inbox rules and OAuth apps.
Restoration order	1. M365 identity tenant → 2. LMS01 staging sandbox → 3. FS01 staging sandbox → 4. Production network.
Recovery time (RTO)	12 hours for LMS01 (exam portal ready by Day 1 08:00 WAT); 24 hours for the FS01 file server.
Recovery point (RPO)	63 hours, based on the disconnected Friday 17:00 WAT backup.
Backup validation	Restore in an isolated sandbox → full EDR/AV scan → database consistency check → 2-hour burn-in with zero alerts → written sign-off from the Business Owner (Registrar) and IR Lead.

Task 4: Communication and Escalation (10 Marks)

4.1 Stakeholder Communication Matrix

Stakeholder	Trigger	Message owner	Channel (alternative)	Approver	Update frequency
100 exam learners	Exam postponement (09:15)	Comms Lead	SMS blast / LMS banner (WhatsApp)	IR Lead and Operations	Immediately, then every 4 hours
Executive / Board	Critical severity declared (08:45)	IR Lead	Phone call / in person (encrypted Signal)	IR Lead	Every 2 hours
All 1,800 learners	General service disruption (09:30)	Comms Lead	SMS / public website notice (social media)	Operations Lead	Daily at 16:00 WAT
IT and security staff	CSIRT activated (08:45)	IR Lead	Encrypted Signal group (staff phone call)	IR Lead	Continuous / hourly
External vendors	Possible M365/ISP compromise	IT Ops Lead	Vendor portal / phone (direct account rep)	IR Lead	As needed / every 4 hours
Legal and privacy	Possible PII exfiltration (09:00)	IR Lead	Encrypted phone / Signal (secure email)	Executive Lead	Every 2 hours / on breach trigger

4.2 Draft Executive Briefing

(Word count: 127)

CONFIDENTIAL EXECUTIVE BRIEFING

TO: Executive Management and Board, Northbridge Skills Institute
FROM: Incident Response Lead | **DATE:** Day 0, 09:15 WAT
SUBJECT: Critical security incident: status and postponement recommendation

At 08:45 WAT we activated the CSIRT after confirming ransomware encryption on finance workstation FIN-PC07 and file server FS01. The learning portal (LMS01) is disrupted because it depends on FS01, which puts the 11:00 WAT online exam for 100 learners at risk.

Confirmed: FS01 shares are inaccessible (.locked files present). Network containment is complete.

Uncertain: Proxy logs show a 1.2 GB upload from FIN-PC07 at 01:50 WAT. We do not yet know whether learner PII was taken. Logons by the svc_backup account to BAK01 need offline integrity checks.

Decisions needed now:

1. Postpone the 11:00 WAT exam to Day 1, 11:00 WAT.
2. Engage the retained external DFIR firm for deep forensic analysis.
3. Approve an emergency $15,000 budget for cloud sandboxing and forensics.

Next update: Day 0, 11:15 WAT.

4.3 Draft Learner Notice

(Word count: 86)

IMPORTANT LEARNER NOTICE: ONLINE EXAMINATION POSTPONEMENT

TO: All registered examination learners (100 candidates)
FROM: Office of the Registrar, Northbridge Skills Institute | **DATE:** Day 0, 09:20 WAT

The online examination scheduled for today (Monday, Day 0) at 11:00 WAT is **postponed** because of technical maintenance on our learning portal.

What you need to do:

1. Please do not log in to the LMS portal for now.
2. The exam is rescheduled to tomorrow (Tuesday, Day 1) at 11:00 WAT.
3. No learner will be penalised, and assessment windows are extended to match.
4. We will send an SMS update with login details by 17:00 WAT today.

We apologise for the inconvenience and thank you for your patience.

4.4 Legal and Privacy Assessment and Regulatory Escalation

Under Section 40 of the Nigeria Data Protection Act (NDPA) 2023, a data controller must notify the Nigeria Data Protection Commission (NDPC) within **72 hours** of becoming aware of a personal data breach that is likely to put data subjects' rights and freedoms at high risk.

Type of notice	Purpose	When
Operational notice	Tells users about downtime without admitting breach liability.	Exam postponement (Day 0, 09:15–09:20).
Formal breach notification	Gives the statutory breach details to the regulator.	After exfiltration is verified, within 72 hours.

Task 5: Tabletop Exercise and Improvement Plan (15 Marks)

5.1 60-Minute Tabletop Exercise Design

Item	Design
Objectives	Test CSIRT decision-making, communication flows, backup restoration steps and crisis management under changing ransomware injects.
Participants	IR Lead, Security Analyst, IT Ops Lead, Legal Adviser, Communications Lead and Business Owner (Registrar).
Agenda (60 min)	0–10 min: introduction and baseline → 10–25: injects 1 and 2 → 25–45: injects 3 and 4 → 45–55: inject 5 → 55–60: debrief.
Success criteria	(1) 100% adherence to the isolation policy; (2) no unauthorised data restoration; (3) decision log updated within 3 minutes of each inject.

5.2 Simulated Decision Log (Five Injects)

Inject	Decision	Owner	Rationale	Communication	Effect on plan
Min 10: Request to reopen portal	Reject the request. Keep the portal offline for the 11:00 exam.	IR Lead	Restoring from unverified backups risks reinfection and data corruption.	Brief Executive Management.	Exam postponed to Day 1, 11:00 WAT.

Inject	Decision	Owner	Rationale	Communication	Effect on plan
Min 20: Attacker threatens to leak 1,800 learners' PII	Refuse ransom negotiation. Engage Privacy Counsel and DFIR to verify the screenshot.	IR Lead and Legal	Paying gives no guarantee, and the screenshot may be generic.	Prepare the NDPC 72-hour notification draft.	Start the legal breach assessment.
Min 35: Backup snapshot error	Switch to the disconnected Friday 17:00 WAT tape backup.	IT Ops	BAK01 is confirmed corrupted or encrypted; the disconnected media is clean.	Inform the CSIRT technical team.	RPO becomes Friday 17:00 WAT.
Min 45: Social media rumour of cancellation	Issue the official learner notice confirming postponement to Day 1.	Comms Lead	Counter the rumour with an authoritative SMS and website notice.	Publish SMS and website banner.	Stops media speculation.
Min 55 (custom): Lateral movement to DC	Isolate the DC01 network segment and enforce a Kerberos reset.	Sec Analyst	Attacker is trying to persist in the domain through a service account.	Alert the Incident Lead.	Eradication expands to Active Directory.

5.3 Post-Incident Improvement Plan

The post-incident review (PIR) is held within 7 days of closure. The IR Lead and the Board Audit Committee close all actions.

Improvement action	Priority	Owner	Target	Measurable evidence
1. Implement immutable cloud backups (WORM)	High	IT Ops Lead	14 days	AWS S3 Object Lock audit report
2. Deploy EDR to 100% of servers	High	Sec Analyst	7 days	EDR agent coverage at 100%
3. Enforce mandatory MFA on M365 and admin accounts	High	Sec Analyst	3 days	Conditional Access enforcement log
4. Set up an offline incident call-tree app	Medium	Comms Lead	14 days	Signal/WhatsApp group verification check
5. Run monthly automated backup restore tests	Medium	IT Ops Lead	30 days	Monthly restore test logs

Task 6: Case Study Analysis and Critical Reflection (10 Marks)

6.1 Healthcare Case Study Critique

(Word count: 94)

This critique is based on the illustrative healthcare ransomware case (GRC105 Week 20 Teaching Deck, Slide 16), where ransomware hit patient EHR systems and clinical workflows.

Area	Findings
Response strengths (3)	1. Clinical continuity plans started at once (paper charts), keeping patients safe during the EHR outage. 2. Executives empowered the incident team to isolate clinical network segments without delay. 3. An external healthcare DFIR retainer sped up root-cause work.
Limitations and unresolved issues (2)	1. Heavy reliance on connected backups: the backup server was encrypted and recovery took days by hand. 2. Poor communication with regional health authorities caused public confusion over emergency room diversion.
Enhancements transferred to Northbridge (2)	1. **Offline baselines:** printed incident contact lists and offline exam procedures for portal outages. 2. **Disconnected backup checks:** physical verification of offline media instead of trusting network backups.

6.2 Critical Reflection Questions

Question 1: 72-hour restoration vs 7-day full restoration

Restoration	What it covers
72-hour	Emergency recovery: core services such as the exam portal are back in a contained staging environment under temporary monitoring.
7-day full	Everything above, plus forensic root-cause analysis, full Active Directory/M365 scrubbing, hardening, rebuilt immutable backups and formal NDPA 2023 breach reporting.

Question 2: Evidence needed to prove no data was stolen

Evidence	What it must show
Firewall, proxy and EDR egress logs for the whole compromise window	No unusual outbound data transfers.
Memory and disk forensics	No staging archives (.zip, .7z) and no exfiltration tools (e.g. Rclone, MegaSync) were run.
M365 Unified Audit Logs	No unauthorised mailbox exports or bulk file downloads.
Dark web monitoring of threat actor activity	No institutional sample files were published.

Question 3: Self-reflection and plan revision

After the tabletop I revised my recovery plan. I had assumed the network backups on BAK01 could be cleaned quickly. Inject 3 showed they can be corrupted or encrypted through the svc_backup credentials. The plan now makes physical retrieval of Friday's disconnected backup the primary recovery path.

References

CISA, FBI, NSA and MS-ISAC. (2023). *#StopRansomware Guide*. Cybersecurity and Infrastructure Security Agency.

ICDFA. (2026). *Incident Response Planning. GRC105: Incident Management and Business Continuity (Week 20 Teaching Deck, Slides 1–18)*. International Cybersecurity and Digital Forensics Academy.

Federal Republic of Nigeria. (2023). *Nigeria Data Protection Act 2023*. Nigeria Data Protection Commission (NDPC).

NIST. (2025). *Special Publication 800-61 Revision 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management*. National Institute of Standards and Technology.